DermAI

Low-Level Design Document

API Endpoint Specifications & Data Schemas

DA5402 MLOps | IIT Madras | Harshit (da25s003) | April 2026

DermAI — API endpoint map

Base URL: http://localhost:8000 · JWT Bearer required where marked

method	endpoint	key inputs → outputs	codes
System endpoints · no auth required			
GET	/	→ name, version, docs	200
GET	/health	→ status, uptime_s, mongodb, model	200
GET	/ready	→ status, device, image_size, model name	200 · 503
GET	/system/info	→ cpu_percent, memory_percent, mongodb_up, uptime_s	200
GET	/classes	→ classes[7] {code, display_name, risk_level}	200
GET	/metrics	→ Prometheus text format · 20+ custom metrics	200
Auth endpoints (/auth) · JWT required where marked			
POST	/auth/signup	username, email, password, gender → uid, email_sent	200 · 409 · 422
POST	/auth/verify-otp	email, otp → account activated message	200 · 400
POST	/auth/resend-otp	email → new OTP sent · invalidates previous OTP	200 · 404 · 409
POST	/auth/login	email, password → access_token (JWT), uid, username	200 · 401 · 403
GET JWT	/auth/me	→ uid, username, email, prediction_count, feedback_co	200 · 401 · 404
GET JWT	/auth/my-predictions	?limit=20 → predictions[], count	200 · 401
Inference endpoints · JWT required on all			
POST JWT	/predict	*input:* file (multipart JPEG/PNG dermoscopy image) *output:* prediction_id · predicted_class · risk_level · confidence · all_scores[7] symptoms · advisory · sources · gradcam_image (base64 PNG) · inference_ms image_saved (bool — persisted to MongoDB for retraining) · timestamp	200 · 400 · 401 · 503
POST JWT	/explain	file + ?class_name → target_class, gradcam_image (base64)	200 · 401 · 503
POST JWT	/feedback	prediction_id, vote (thumbs_up|thumbs_down), comment →	200 · 401 · 422
GET JWT	/feedback/stats	→ total, thumbs_up, thumbs_down, positive_rate	200 · 401
GET JWT	/predictions/stats	→ total_predictions, by_class[], high_risk_total	200 · 401

MongoDB document schemas · 6 collections

users	predictions	images
uid (UUID, PK, unique) email (unique) · username (uniqu password_hash · verified · gende prediction_count · feedback_co	prediction_id (UUID, PK) uid · username · predicted_class confidence · risk_level · all_scores inference_ms · image_id · timestam	image_id (UUID, PK) prediction_id · uid · username filename · image_size_kb image_b64 (for retraining)

feedback	otp_store	request_log
prediction_id (PK, one per predic uid · username · vote · comment timestamp	email (unique) otp · expires_at TTL index — auto-deleted after 10	uid · endpoint timestamp (indexed) TTL index — auto-deleted after 1 hour

GET (read) · POST (write/action) · JWT JWT Bearer token require · 503 = model not yet loaded

1. Base URL & Auth

Base URL:

```
http://localhost:8000
```

Authentication: JWT Bearer Token. Obtain via POST /auth/login.

```
Authorization: Bearer <access_token>
```

All endpoints marked Auth: Required will return HTTP 401 if the token is missing or invalid.

2. System Endpoints

GET `/ — Root`

Returns API name, version, and doc links.

Auth: Not required

Response Body (JSON):

Field	Type	Description
name	string	API name: 'Skin Disease Detection API'
version	string	Current version: '2.0.0'
docs	string	URL to Swagger UI
ready	string	URL to ready endpoint
health	string	URL to health endpoint

HTTP Status Codes:

Code	Meaning
200	Success — always

GET `/health — Health Check`

Returns API and dependency health status.

Auth: Not required

Response Body (JSON):

Field	Type	Description
status	string	'ok' (always 200 if backend is running)
uptime_s	float	Seconds since server start
mongodb	string	'up' or 'down'
model	string	'loaded' or 'not loaded'

HTTP Status Codes:

Code	Meaning
200	Always returns 200 if server is reachable

GET	`/ready — Readiness` Returns 200 only when model is loaded. Use for startup checks. Auth: Not required

Response Body (JSON):

Field	Type	Description
status	string	'ready'
device	string	'cpu' or 'cuda'
image_size	int	Input image size (336)
model	string	Model name (efficientnet_b3)

HTTP Status Codes:

Code	Meaning
200	Model ready
503	Model not yet loaded (during startup)

GET	`/system/info — System Info` Live system resource snapshot. CPU and memory from psutil. Auth: Not required

Response Body (JSON):

Field	Type	Description
cpu_percent	float	Current CPU utilisation %
memory_percent	float	RAM utilisation %
memory_used_gb	float	RAM used in GB
memory_total_gb	float	Total RAM in GB
device	string	'cpu' or 'cuda'
mongodb_up	bool	true if MongoDB is reachable
users_registered	int	Total registered users
users_verified	int	Total verified users
Python_version	string	Python version of system “3.10.20”
uptime_s	float	API uptime in seconds

HTTP Status Codes:

Code	Meaning
200	Always

GET	`/classes — Disease Classes` Returns all 7 supported disease classes with risk levels. Auth: Not required

Response Body (JSON):

Field	Type	Description
classes	array	Array of 7 class objects
classes[].code	string	Short code: akiec|bcc|bkl|df|mel|nv|vasc

Field	Type	Description
classes[].display_name	string	Full name e.g. 'Melanoma'
classes[].risk_level	string	HIGH | MEDIUM | LOW

HTTP Status Codes:

Code	Meaning
200	Always

GET `/metrics — Prometheus Metrics`

Prometheus text format exposition of all 20+ custom metrics.

Auth: Not required

Response Body (JSON):

Field	Type	Description
(body)	text	Prometheus text format metrics

HTTP Status Codes:

Code	Meaning
200	Always

3. Auth Endpoints (prefix: /auth)

POST `/auth/signup — Register`

Creates a new unverified user account and sends a 6-digit OTP to the provided email.

Auth: Not required

Request Body (JSON):

Field	Type	Required	Description
username	string	Yes	3-50 characters, unique
email	string (email)	Yes	Valid email, unique
password	string	Yes	Minimum 8 characters
gender	string	No	male|female|other|prefer_not_to_say (default)

Response Body (JSON):

Field	Type	Description
message	string	Confirmation message
uid	string	New user UUID
email_sent	bool	true if OTP email was delivered

HTTP Status Codes:

Code	Meaning
200	User created, OTP sent
409	Email or username already registered
422	Validation error (short username, bad email, short password)

Code	Meaning
500	OTP generation failed — retry

POST `/auth/verify-otp — Verify OTP`

Verifies the 6-digit OTP sent to email. Activates the user account.

Auth: Not required

Request Body (JSON):

Field	Type	Required	Description
email	string (email)	Yes	Email used at signup
otp	string	Yes	6-digit OTP from email

Response Body (JSON):

Field	Type	Description
message	string	'Email verified successfully. You can now login.'

HTTP Status Codes:

Code	Meaning
200	Account activated
400	Invalid or expired OTP

POST `/auth/resend-otp — Resend OTP`

Generates and sends a new OTP. Invalidates the previous OTP.

Auth: Not required

Request Body (JSON):

Field	Type	Required	Description
email	string (email)	Yes	Registered email

Response Body (JSON):

Field	Type	Description
message	string	Confirmation

HTTP Status Codes:

Code	Meaning
200	New OTP sent
404	Email not registered
409	Email already verified

POST `/auth/login — Login`

Authenticates with email+password. Returns a JWT access token. Only verified accounts can login.

Auth: Not required

Request Body (JSON):

Field	Type	Required	Description
email	string (email)	Yes	Registered and verified email

Field	Type	Required	Description
password	string	Yes	Account password

Response Body (JSON):

Field	Type	Description
access_token	string	JWT Bearer token (use in Authorization header)
token_type	string	'bearer'
uid	string	User UUID
username	string	Username
email	string	Email address

HTTP Status Codes:

Code	Meaning
200	Login successful
401	Invalid email or password
403	Account not verified — check email for OTP

GET `/auth/me — My Profile`

Returns the authenticated user's profile with prediction and feedback counts.
Auth: Required

Response Body (JSON):

Field	Type	Description
uid	string	User UUID
username	string	Username
email	string	Email
gender	string	Gender
verified	bool	Email verified status
created_at	string	ISO 8601 timestamp
prediction_count	int	Total predictions made
feedback_count	int	Total feedback given

HTTP Status Codes:

Code	Meaning
200	Success
401	Token missing or invalid
404	User not found in DB

GET `/auth/my-predictions — Prediction History`

Returns the authenticated user's prediction history. Query param: limit (default 20).
Auth: Required

Response Body (JSON):

Field	Type	Description
uid	string	User UUID

Field	Type	Description
predictions	array	List of prediction objects (see §4 schema)
count	int	Number of records returned

HTTP Status Codes:

Code	Meaning
200	Success
401	Token missing or invalid

4. Inference Endpoints

POST	`/predict — Classify Image` Uploads a dermoscopy image. Returns classification, confidence, Grad-CAM heatmap, symptoms, advisory. Image is saved to MongoDB for future retraining. Auth: Required

Request Body (JSON):

Field	Type	Required	Description
file	multipart/form-data	Yes	JPEG/PNG skin image. Min 50×50px recommended.

Response Body (JSON):

Field	Type	Description
prediction_id	string	UUID for this prediction (use for feedback)
predicted_class	string	akiec|bcc|bkl|df|mel|nv|vasc
display_name	string	Full disease name e.g. 'Melanoma'
risk_level	string	HIGH|MEDIUM|LOW
confidence	float	Model confidence 0.0–1.0
all_scores	object	Score for each of 7 classes
symptoms	array	List of associated symptoms
advisory	string	Clinical advisory text
sources	array	Array of {name, url} reference links
gradcam_image	string	... Grad-CAM heatmap
disclaimer	string	'AI-assisted assessment only. NOT a substitute...'
inference_ms	float	Model inference time in milliseconds
total_ms	float	Total request time in milliseconds
image_saved	bool	true if image was persisted to MongoDB
timestamp	string	ISO 8601 UTC timestamp

HTTP Status Codes:

Code	Meaning
200	Prediction successful
400	Invalid or unreadable image
401	Token missing or invalid

Code	Meaning
503	Model not yet loaded

POST `/explain — GradCAM for Specific Class`

Returns a Grad-CAM heatmap for a specified disease class (or the top predicted class if class_name omitted). Query param: class_name (optional).

Auth: Required

Request Body (JSON):

Field	Type	Required	Description
file	multipart/form-data	Yes	Dermoscopy image
class_name	query param	No	akiec|bcc|bkl|df|mel|nv|vasc

Response Body (JSON):

Field	Type	Description
target_class	string	Class used for Grad-CAM
display_name	string	Full disease name
gradcam_image	string	... heatmap

HTTP Status Codes:

Code	Meaning
200	Success
401	Unauthorised
503	Model not loaded

POST `/feedback — Submit Feedback`

Records user feedback (thumbs up/down) for a prediction. One feedback per prediction_id — subsequent calls update the existing record.

Auth: Required

Request Body (JSON):

Field	Type	Required	Description
prediction_id	string	Yes	UUID from /predict response
vote	string	Yes	'thumbs_up' or 'thumbs_down'
comment	string	No	Optional free-text comment

Response Body (JSON):

Field	Type	Description
status	string	'recorded'
prediction_id	string	Echo of the prediction_id
vote	string	Echo of the vote
stored_in	string	'mongodb' or 'memory'

HTTP Status Codes:

Code	Meaning
200	Feedback recorded
401	Unauthorised
422	Invalid vote value (not thumbs_up or thumbs_down)

GET `/feedback/stats — Feedback Statistics`

Returns aggregated feedback statistics across all users.
Auth: Required

Response Body (JSON):

Field	Type	Description
total	int	Total feedback records
thumbs_up	int	Count of positive feedback
thumbs_down	int	Count of negative feedback
positive_rate	float	Ratio thumbs_up / total (0.0–1.0)

HTTP Status Codes:

Code	Meaning
200	Success
401	Unauthorised

GET `/predictions/stats — Prediction Statistics`

Returns aggregated prediction statistics across all users.
Auth: Required

Response Body (JSON):

Field	Type	Description
total_predictions	int	Total predictions served
by_class	object	Count per disease class
high_risk_total	int	Count of HIGH risk (melanoma) predictions

HTTP Status Codes:

Code	Meaning
200	Success
401	Unauthorised

5. MongoDB Data Schemas

5.1 User Document

Field	Type	Description
uid	string	UUID v4 — primary key
username	string	Lowercase, unique

Field	Type	Description
email	string	Lowercase, unique
password_hash	string	SHA-256 hash — never returned in API
gender	string	male|female|other|prefer_not_to_say
verified	bool	false until OTP confirmed
created_at	string	ISO 8601 UTC
prediction_count	int	Incremented on each /predict call
feedback_count	int	Incremented on each /feedback call

5.2 Prediction Document

Field	Type	Description
prediction_id	string	UUID v4 — primary key
uid	string	Owner user UUID
username	string	Owner username
predicted_class	string	akiec|bcc|bkl|df|mel|nv|vasc
confidence	float	0.0–1.0
risk_level	string	HIGH|MEDIUM|LOW
all_scores	object	Score for all 7 classes
inference_ms	float	Inference duration in ms
image_id	string	Reference to images collection
image_filename	string	Original upload filename
timestamp	string	ISO 8601 UTC

5.3 Feedback Document

Field	Type	Description
prediction_id	string	UUID v4 — primary key (one per prediction)
uid	string	Voter user UUID
username	string	Voter username
vote	string	thumbs_up | thumbs_down
comment	string	Optional free-text (may be empty string)
timestamp	string	ISO 8601 UTC

5.4 Image Document

Field	Type	Description
image_id	string	UUID v4
prediction_id	string	Linked prediction

Field	Type	Description
uid	string	Owner user UUID
username	string	Owner username
filename	string	Original upload filename
image_b64	string	Base64-encoded JPEG — for future retraining
image_size_kb	float	File size in kilobytes
timestamp	string	ISO 8601 UTC

5.5 Otp store

Field	Type	Description
email	string	Lowercase, unique
expires_at	string	ISO 8601 UTC
otp	string	6-digit random numeric code